Universiti Tun Hussein Onn Malaysia

UNIVERSITI TUN HUSSEIN ONN MALAYSIA

FINAL EXAMINATION
SEMESTER I
SESSION 2024/2025

COURSE NAME	:	SOFTWARE SECURITY
COURSE CODE	:	BIS 20503
PROGRAMME CODE	:	BIS
EXAMINATION DATE	:	FEBRUARY 2025
DURATION	:	3 HOURS
INSTRUCTIONS	:	1. ANSWER ALL QUESTIONS 2. THIS FINAL EXAMINATION IS CONDUCTED VIA ☐ Open book ☒ Closed book 3. STUDENTS ARE **PROHIBITED** TO CONSULT THEIR OWN MATERIAL OR ANY EXTERNAL RESOURCES DURING THE EXAMINATION CONDUCTED VIA CLOSED BOOK

TERBUKA

THIS QUESTION PAPER CONSISTS OF **FIVE (5)** PAGES

Q1 XYDigital Corporation, a multinational company, experienced a significant data breach. Hackers exploited a vulnerability in the company's database management system, gaining unauthorized access to sensitive customer information, including personal identification numbers, credit card details, and transaction histories. The breach went undetected for several months, resulting in substantial financial losses and reputational damage. Assume you were a database administrator at XYDigital Corporation.

Based on the given scenario, answer the following questions.

(a) Explain the primary cause of the data breach.

(2 marks)

(b) Explain the difference between authentication and authorization in database management system.

(4 marks)

(c) Discuss **ONE (1)** authentication method that XYDigital could implement to prevent similar breaches in the future.

(5 marks)

(d) Discuss Role-Based Access Control (RBAC) relates to authorization in database security.

(5 marks)

(e) Identify **FOUR (4)** categories of database users with RBAC.

(4 marks)

Q2 A software development company, SecureSoft Inc., is developing a new online banking application. The application must handle sensitive user data, including personal information and financial transactions. The company aims to ensure the highest level of security throughout the software development lifecycle. Assume you are the Head of Software Developer team. You have decided to follow secure software design principles and implement various security measures to protect against potential threats.

Based on the given scenario, answer the following questions.

(a) Identify **FIVE (5)** security principles to be included in system design phase.

(5 marks)

(b) Explain **TWO (2)** approaches SecureSoft Inc. can use encryption to protect sensitive user data in the online banking application.

(4 marks)

(c) Propose **FIVE (5)** backup and rollback strategies for the online banking application.

TERBUKA

(10 marks)

(d) Discuss **THREE (3)** Favor Simplicity (FS) approaches that can be applied in the online banking application.

(6 marks)

Q3 An e-commerce company, ShopSecure Sdn. Bhd. has been experiencing security breaches due to poor coding practices. The company has decided to revamp its coding standards to ensure better security. They have identified several vulnerabilities in their current system, including SQL injection, cross-site scripting (XSS), and improper error handling. As a security consultant, you are tasked with analyzing the existing codebase, identifying vulnerabilities, and suggesting secure coding practices to mitigate these issues.

Based on the given scenario, answer the following questions.

(a) Explain the **THREE (3)** vulnerabilities found in the ShopSecure's codebase.

(6 marks)

(b) Suggest **TWO (2)** good code practices to prevent SQL injection.

(4 marks)

(c) Suggest **FIVE (5)** rules for errors to improve the improper error handling.

(5 marks)

(d) Analyze the importance of applying the following code snippet in **Figure Q3.1.**

(5 marks)

```
String row1=(String)request.getAttribute('row1");
If (row1 != null)
row1 = row1.replaceAll("<","&lt;");
row1 = row1.replaceAll(">","&gt;");
row1 = row1.replaceAll("&","&amp;");
row1 = row1.replaceAll ("/","&#x2F;");
if (row1.indexOf("1:") >=0){
int index = (int)row1.indexOf("1:");
out.println(",td."+row1.substring(index+2,
index+5)+"</td>");
} else
Out.println("<td> </td>");
```

Figure Q3.1 Secure coding code snippet

TERBUKA

Q4 An online retailer, Hijabi Sdn. Bhd., has suffered a significant cyber incident, compromising personal contact details of customers. Assume you are the security expert investigating the incident to ascertain the exact cause and extent of the breach. Preliminary investigations have revealed that the incident was primarily caused by a lack of regular Operating System (OS) server maintenance. Outdated software, unpatched vulnerabilities, and weak configuration settings were identified as key contributing factors.

Based on the given scenario, answer the following questions.

(a) Propose **FIVE (5)** specific security maintenance strategies of the National Institute Standards and Technology (NIST).

(10 marks)

(b) Explain data backup and data archive practices could minimize the risk of data loss to Hijabi Sdn. Bhd.

(5 marks)

Q5 Assume you are tasked with migrating a legacy application currently running on a virtual machine to a containerized environment for Universiti Tun Hussein Onn Malaysia (UTHM). The migration is important to ensure a smooth transition and improve the UTHM applications' efficiency using containers.

Based on the given scenario, answer the following questions.

(a) Describe the differences between servers, virtualization and containers.

(6 marks)

(b) Suggest **THREE (3)** security best practices for containers and orchestration that can be implemented in UTHM.

(6 marks)

(c) Answer all questions based on the **Figure Q5.1**.

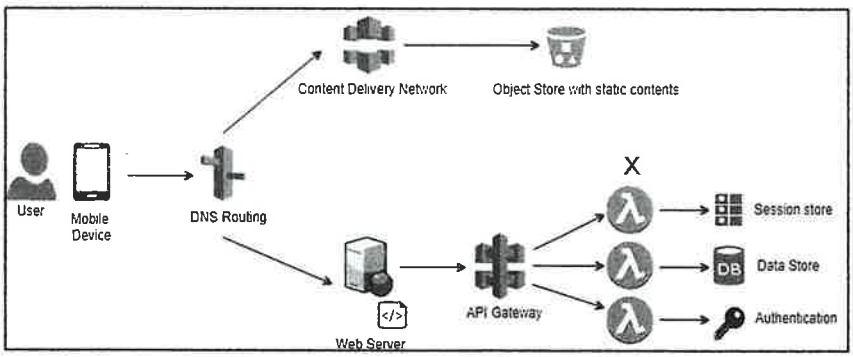


Figure Q5.1 The proposed architecture

TERBUKA

(i) Describe x.

(2 marks)

(ii) Explain x operation with containers.

(2 marks)

(iii) Propose **TWO (2)** specific security strategies of x for UTHM network infrastructure.

(4 marks)

- END OF QUESTIONS -

TERBUKA